

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

PROCEDURA DI GESTIONE DEI DATA BREACH

Gestione delle violazioni dei dati personali
ai sensi dell'art. 33-34 GDPR

Codice	Revisione	Data	Pagine
TD-SGI-PRO057_00	00	16/04/2026	4
Redatto da	Approvato da	Classificazione	Stato
RSGI	Direzione Generale	Interno	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
16/04/2026	16/04/2026	16/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

DEFINIZIONI

Data Breach (Violazione di dati personali)

- Una violazione della sicurezza che comporta, accidentalmente o illegittimamente, la distruzione, la perdita, la modifica, la diffusione non autorizzata o l'accesso non autorizzato a dati personali trasmessi, conservati o comunque trattati.

Evento di Sicurezza

- Ogni episodio che potrebbe compromettere la riservatezza, l'integrità o la disponibilità dei dati personali.

SCOPO E CAMPO DI APPLICAZIONE

La presente procedura descrive le modalità di identificazione, valutazione, gestione e documentazione delle violazioni dei dati personali (Data Breach) ai sensi degli art. 33-34 del GDPR n. 679/2016, al fine di garantire una risposta tempestiva ed appropriata e il rispetto dei termini di notifica alle autorità competenti.

RIFERIMENTI NORMATIVI

- Regolamento UE n. 679/2016 (GDPR), artt. 33-34
- D.Lgs. 196/2003 e s.m.i. (Codice della Privacy)
- Linee guida dell'EDPB in tema di notifica di Data Breach
- Registro Data Breach (TD-SGI-REG007_00)

RESPONSABILITÀ

Responsabile di Area/Processo

- Rileva l'evento di sicurezza e ne comunica l'accadimento al Team Privacy senza ingiustificato ritardo, allegando il Report Data Breach.

Data Protection Officer (DPO)

- Valuta il Data Breach, determina se comporta rischi per diritti e libertà degli interessati, coordina la risposta e supervisiona la conformità ai termini di legge.

Team Privacy/Titolare

- Gestisce la comunicazione alle autorità, agli interessati e ai partner, secondo le scadenze previste.

PROCEDURA DI GESTIONE DEL DATA BREACH

FASE 1: RILEVAZIONE E SEGNALAZIONE

- Rilevazione dell'evento
- Identificazione di un evento che potrebbe costituire violazione di dati personali (accesso non autorizzato, perdita, modifica, diffusione non autorizzata).
- Segnalazione immediata al Team Privacy
- Responsabile di Area informa senza ritardo il Team Privacy mediante Report Data Breach, allegando: natura dell'evento, categorie di dati coinvolti, numero di interessati, possibili conseguenze, misure tecniche implementate, contatti per follow-up.

FASE 2: VALUTAZIONE INIZIALE (ENTRO 4 ORE)

- La valutazione deve essere completata entro 4 ore dalla segnalazione.
- Raccolta informazioni complete
- Il Team Privacy raccoglie tutti i dettagli necessari: circostanze del breach, dati interessati, responsabili, misure di mitigazione immediate.
- Notifica al DPO
- Comunicazione immediata della segnalazione al DPO con tutta la documentazione disponibile.
- Registrazione preliminare

- Inserimento dell'evento nel Registro Data Breach (TD-SGI-REG007_00) con status "In Valutazione".

FASE 3: ASSESSMENT FORMALE E MATRICE DI RISCHIO (ENTRO 24 ORE)

- Entro 24 ore dalla segnalazione, il DPO deve completare una valutazione formale del rischio.

Metodologia di Valutazione del Rischio

La valutazione utilizza una matrice di rischio che incrocia due dimensioni:

PROBABILITÀ DI DANNO:

- Bassa: evento isolato, dati non sensibili, interessati pochi, misure di protezione efficaci
- Media: evento con contenimento parziale, dati sensibili limitati, interessati moderati
- Alta: evento diffuso, dati altamente sensibili, interessati numerosi, misure di protezione compromesse

IMPATTO POTENZIALE:

- Basso: danno minimo ai diritti e libertà (es. dati pubblici, name+email di aziende)
- Medio: danno significativo (es. dati bancari limitati, comunicazioni private)
- Alto: danno grave (es. dati sanitari, biometrici, situazioni di vulnerabilità)

MATRICE DI RISCHIO - LIVELLI:

- LOW (Bassa Probabilità + Basso Impatto): Notifica Garante non obbligatoria. Comunicazione agli interessati opzionale.
- MEDIUM (Media Probabilità O Medio Impatto): Notifica Garante consigliata. Comunicazione agli interessati probabile.
- HIGH (Alta Probabilità O Alto Impatto): Notifica Garante obbligatoria. Comunicazione agli interessati obbligatoria.
- CRITICAL (Alta Probabilità + Alto Impatto): Notifica Garante urgente (72 ore). Comunicazione agli interessati urgente. Coinvolgimento Media/Autorità.

FASE 4: DECISIONE E PIANIFICAZIONE (ENTRO 48 ORE)

- Entro 48 ore dalla segnalazione deve essere assunta la decisione finale sulle azioni da intraprendere.

Decisione su Notifica Garante

- Il DPO e il Titolare determinano se il rischio per diritti e libertà è sufficientemente elevato da richiedere notifica all'Autorità (Garante Privacy).

Decisione su Comunicazione Interessati

- Valutazione se vi è rischio elevato per gli interessati. Se SÌ, preparazione della comunicazione. Se NO (ma notifica Garante avviene), documentazione delle eccezioni.

Pianificazione delle azioni

- Definizione della timeline per invio notifiche e comunicazioni, raccolta evidenze, update del Registro Data Breach.

FASE 5: NOTIFICA GARANTE PRIVACY (ENTRO 72 ORE)

Art. 33 GDPR - TERMINE TASSATIVO:

La notifica al Garante Privacy deve avvenire ENTRO 72 ORE (3 giorni) dalla scoperta della violazione, senza ingiustificato ritardo.

FASE 6: COMUNICAZIONE AGLI INTERESSATI (SE APPLICABILE)

- Se il rischio è ELEVATO per i diritti e libertà degli interessati, la comunicazione è OBBLIGATORIA.

FASE 7: DOCUMENTAZIONE E REGISTRO DATA BREACH

- Tutte le operazioni devono essere registrate nel Registro Data Breach (TD-SGI-REG007_00).